山东大学
网络空间安全学院

《网络安全》
实验报告

学生姓名	江李阳 (202400460042) 王健一 (202400460037) 邱泽辉 (202400460046)
指导教师	郭山清
学院	网络空间安全学院
专业班级	密码科学与技术 2024 级一班
完成时间	2026 年 11 月 2 日

1 实验目的

2 实验原理

2.1 互联网域名解析

互联网域名解析过程由四个关键服务器发挥作用，分别为:

- 递归域名服务器：位于用户端与域名服务器之间，负责处理用户端发起的域名解析请求。在接收到用户端发起的域名查询请求后，递归解析服务器会逐层向根域名服务器、顶级域名服务器、权威域名服务器发送请求，直到获得域名对应的 IP 地址，并将查询结果返回给用户端；
- 根服务器：是域名系统中域名解析流程的起点，主要作用是提供顶级域名服务器和权威域名服务器信息；
- 顶级域名服务器：负责存储与顶级顶级域名相关的信息及其下所有域名的权威服务器的信息，在域名解析流程中，顶级域名服务器负责提供域名的权威服务器地址，帮助递归解析服务器完成定位；
- 权威服务器：负责提供域名的所有信息，包括 IP 地址、邮件服务器等。

2.2 DNS 缓存污染攻击

为了提高域名解析的性能，减轻权威服务器侧的网络流量负载，递归服务器引入了缓存机制，即递归解析服务器在接收到查询的域名相应后，可将其中的信息存储在本地一段时间，缓存时间由权威服务器指定。在同一网络环境内其他用户所要查询的域名信息已被缓存，那么递归解析服务器可以直接返回缓存数据，无需再向远程的权威服务器重复发送查询请求。

缓存污染攻击的目的是为了篡改域名在缓存中的资源记录，以进一步实现网络钓鱼、传播恶意软件或收集用户敏感信息等。该攻击能实现的根源在于域名协议报文缺乏消息完整性验证的检查。攻击者通过发送精心构造的 DNS 响应报文来欺骗递归解析服务器，使其将错误的解析结果存储在缓存中（缓存保存有时间限制）。当递归解析服务器被污染，缩用使用该递归解析服务器的互联网用户在解析该域名时都会被错误重定向。

上述攻击的关键在于，攻击者发送的伪造 DNS 响应报文能被递归解析服务器所接受，这在于以下字段核验通过：

- IP 地址匹配：这一条符合，因为响应的源 IP 地址为权威服务器地址，目的地址为递归解析服务器地址，均已知；

- 端口匹配：响应报文的源端口为 DNS 服务端口，属于常见端口为 53，但目的端口为递归解析服务器发送请求时的随机端口，该值未知，需要遍历猜测。
- TXID 匹配：响应 TXID 于请求 TXID 相等，该值无法提前获知，需要遍历猜测。
- 问题区域匹配：通过攻击者自行发起 DNS 解析服务，从而问题区内容有攻击者掌握，这一条符合。

以上所有字段核验通过后还要求攻击者伪造的响应比权威服务器的真实响应先到达递归解析服务器。上述 16 位源端口和 16 位 TXID 待遍历，意味着总的遍历次数为

$$2^{16} \times 2^{16} = 2^{32}$$

即需要在权威服务器返回真实响应前做完 2^{32} 次枚举，并将所有伪造响应都发送到递归解析服务器，DNS 污染攻击才能成功。